

VEREDITO GERAL: APROVADO (NÍVEL EXECUTIVO CORPORATIVO)

Plataforma em estrita conformidade com a PSI do Grupo Vaccaro e com a Governança SGQ / ISO 9001.

HOMOLOGADO

1. ESCOPO E OBJETIVOS DA AUDITORIA TÉCNICA

Esta auditoria avalia a resiliência arquitetural, controles de acesso e integridade de dados do Lean Flow System, compreendendo o front-end Next.js 14 App Router, rotas de API protegidas, integrações de IA e a base de dados PostgreSQL no Supabase (projeto dompnslzzudznbhyhyfz, sa-east-1). O escopo incluiu a resolução definitiva do bloqueio de colaboradores pré-cadastrados no SSO (Microsoft Entra ID) e a aplicação de 4 patches de hardening SecOps homologados.

2. MATRIZ DE CONFORMIDADE DOS 9 PILARES SECOPS

| PILAR DE SEGURANÇA                 | STATUS   | MECANISMO DE CONTROLE E EVIDÊNCIA TÉCNICA                                                                                                        |
|------------------------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. RLS & Zero Acesso Anônimo       | CONFORME | REVOKE ALL ON ALL TABLES IN SCHEMA public FROM anon ativo. 100% das tabelas produtivas com RLS habilitado e isolamento multi-tenant (tenant_id). |
| 2. Storage & Buckets Privados      | CONFORME | Buckets de fotos do Gemba e laudos 5S/TPM estritamente privados. Acesso mediado por URLs temporárias assinadas (Signed URLs).                    |
| 3. Zero Dados no Bundle Público    | CONFORME | Sem custos, clientes ou parâmetros confidenciais hardcoded. Chaves sensíveis removidas de prefixos NEXT_PUBLIC_.                                 |
| 4. Governança de Chaves de IA      | CONFORME | GEMINI_API_KEY 100% no servidor. Rota /api/ai/sensei exige Bearer JWT corporativo. Zero chaves armazenadas no localStorage.                      |
| 5. Integridade SGQ / ISO 9001      | CONFORME | Triggers PostgreSQL impedem spoofing de aprovações. Cravamento automático de autoria via auth.uid() e validação Master.                          |
| 6. API Routes & Server Actions     | CONFORME | Validação de token corporativo via supabase.auth.getUser(token). Auditoria de custos protegida por tokens unívocos.                              |
| 7. Trava de Domínio & SSO Entra ID | CONFORME | Trigger rejeita e-mails fora de @rafitec.com.br e @vaccaro.com.br. Whitelist corporativa centralizada na nuvem (public.authorized_users).        |
| 8. Expurgo em Terminais do Gemba   | CONFORME | Logout com higienização atômica varrendo prefixos lean_flow_*, sensei_* e gemini_* em máquinas compartilhadas no chão de fábrica.                |
| 9. Funções de Banco & Search Path  | CONFORME | Cláusula SET search_path = public; em todas as funções SECURITY DEFINER. RPCs analíticas isoladas no schema private.                             |

3. RESOLUÇÃO DE BLOQUEIO DE SSO & HARDENING DE API

A. Centralização da Whitelist no Supabase (Eliminação da Dependência de localStorage)

Causa Raiz: O cadastro de agentes residia exclusivamente no localStorage do navegador do gestor. Em estações de trabalho de colaboradores (ex: Leonardo Ogliari e Juliano Zancanaro), a verificação de login falhava por ausência do registro local.

Solução Implementada: Criada a tabela public.authorized\_users com RLS e trigger handle\_new\_auth\_user() no Supabase. O fluxo de login em src/app/page.tsx agora valida em 3 camadas, concedendo acesso corporativo imediato em qualquer terminal da empresa.

B. Validação Mandatória de Token Bearer JWT na API de IA (/api/ai/sensei)

Vulnerabilidade Anterior: A rota POST aceitava invocações sem validação de sessão ativa no servidor, expondo a chave corporativa de IA a requisições sem rastreabilidade.

Patch Aplicado: Implementada extração de token Bearer com conferência direta via supabase.auth.getUser(token). Chamadas anônimas são rejeitadas com status HTTP 401 Unauthorized. O cliente geminiService.ts despacha automaticamente o token da sessão em todas as requisições.

```
const { data: { user }, error } = await supabase.auth.getUser(token);
if (error || !user) return NextResponse.json({ error: 'Sessão corporativa inválida.' }, { status: 401 });
```

C. Eliminação de Chaves em localStorage & Expurgo Total no Logout

Vulnerabilidade Anterior: O painel de integrações gravava a API key no localStorage do cliente. O logout preservava resíduos de chaves locais.

Patch Aplicado: Removida a persistência em texto puro em /admin/integracoes-ia (agora informativo da variável do servidor). A função logout em AuthContext.tsx itera por todas as chaves e remove atômica e recursivamente qualquer registro sob os prefixos lean\_flow\_\*, sensei\_\* e gemini\_\*

4. CHECKLIST DE CONFORMIDADE SECOPS (GRUPO VACCARO)

|   |                                                                             |   |                                                                            |
|---|-----------------------------------------------------------------------------|---|----------------------------------------------------------------------------|
| X | RLS ativo e Grants anônimos revogados (REVOKE ALL FROM anon auditado)       | X | Zero credenciais corporativas no bundle client (sem NEXT_PUBLIC_ sensível) |
| X | Chaves de IA mantidas 100% no servidor (sem armazenamento em localStorage)  | X | Validação de token Bearer corporativo em todas as rotas de backend         |
| X | Triggers de auditoria e conformidade SGQ / ISO 9001 blindadas no PostgreSQL | X | Whitelist multi-tenant centralizada no banco de dados para acesso SSO      |
| X | Expurgo atômico de dados em terminais compartilhados no Gemba fabril        | X | Trava restrita a e-mails corporativos homologados (@rafitec.com.br)        |

5. RECOMENDAÇÕES COMPLEMENTARES DE GOVERNANÇA

- Leaked Password Protection: Habilitar o alerta de senhas vazadas no painel do Supabase Auth para proteção adicional de credenciais locais de contingência.
- E-mails Transacionais: Manter as notificações de custos encapsuladas via rotas de backend ou Edge Functions, preservando isolamento de chaves de e-mail.
- Índices de Cobertura: Monitorar o crescimento das tabelas de alto volume operacional (action\_checklists, tpm\_tags) criando índices específicos de foreign keys.

Arquiteto Sênior de AppSec

Auditoria de Segurança da Informação & SecOps

Rafitec S.A. / Grupo Vaccaro

Mauricio Grigol

Root Master / Gestor de Governança & TI Industrial

Rafitec S.A. / Grupo Vaccaro